جامعة المنصورة
Mansoura University
كلية الحاسبات والمعلومات
Faculty of Computers and Information Sciences

*Higher Diploma in Information Security*

# Securing Generative AI Applications Using Zero Trust Architecture:

## A Framework for Protecting Sensitive Data in Higher Education Institutions

## تأمين تطبيقات الذكاء الاصطناعي التوليدي باستخدام بنية "أنعدام الثقة":
## إطار عمل لحماية البيانات الحساسة في مؤسسات التعليم العالي




**Prepared By :-**

Mohamed Hamed Mohamed
EL-Gharieb Sallam

**Supervised By:-**

Prof :- Samir
Mohamed Abdel-Razek

2026

# Abstract

The rapid integration of generative artificial intelligence (GenAI) into higher education has introduced significant productivity gains alongside serious security, privacy, and governance risks. Large language models (LLMs) deployed for academic advising, research assistance, administrative automation, and student support routinely process sensitive data, including personally identifiable information (PII), academic records, and proprietary research material. Traditional perimeter-based security models, which implicitly trust users and systems once inside the network boundary, are insufficient to address the dynamic, data-centric threats introduced by GenAI systems. This research proposes a Zero Trust Architecture (ZTA) framework, grounded in NIST SP 800-207, tailored specifically to the operational realities of higher education institutions deploying generative AI applications. The framework integrates continuous identity verification, micro-segmentation, least-privilege access control, data-centric encryption, and real-time behavioral monitoring across the AI application lifecycle. A case study modeled on a typical university computing environment is used to evaluate the framework's feasibility, and the results indicate measurable improvements in access control granularity, reduction of lateral movement risk, and improved compliance posture with data protection regulations. The paper concludes with practical recommendations for IT governance teams seeking to adopt Zero Trust principles when integrating generative AI into academic environments.


**Keywords:** *Zero Trust Architecture; Generative AI; Large Language Models; Higher Education Cybersecurity; Data Privacy; Access Control; AI Governance*

# Contents

Abstract ..... 2
1. Introduction ..... 5
1.1 Problem Statement ..... 8
1.2 Research Objectives ..... 8
1.3 Scope and Significance ..... 8
2. Background of Generative AI ..... 10
3. Cybersecurity Challenges in Higher Education ..... 11
3.1 Decentralized IT Governance ..... 11
3.2 High-Value, High-Volume Data ..... 11
3.3 Open and Heterogeneous User Base ..... 11
3.4 Resource and Expertise Constraints ..... 11
3.5 Legacy Systems and Shadow IT ..... 12
3.6 Summary of Structural Challenges ..... 12
4. Generative AI Security Threats ..... 13
4.1 Prompt Injection ..... 13
4.2 Sensitive Data Exposure and Leakage ..... 13
4.3 Insecure Output Handling ..... 13
4.4 Excessive Agency and Over-Permissioned Integrations ..... 13
4.5 Model and Supply Chain Risks ..... 14
4.6 Denial of Service and Resource Exhaustion ..... 14
4.7 Shadow AI and Unsanctioned Tool Use ..... 14
4.8 Prioritizing the Threat Landscape ..... 14
5. Zero Trust Architecture ..... 16
5.1 Core Tenets ..... 16
5.2 Core Logical Components ..... 16
5.3 Why Zero Trust Fits Generative AI ..... 17
6. Related Work and Literature Review ..... 18
7. Proposed Framework ..... 19
7.1 Layer 1: Identity and Access Verification ..... 19
7.2 Layer 2: Data Classification and Segmentation ..... 19
7.3 Layer 3: Least-Privilege AI Integration ..... 20
7.4 Layer 4: Inference-Time Policy Enforcement ..... 20

7.5 Layer 5: Continuous Monitoring and Audit ..... 20
7.6 Framework Summary ..... 20
8. Research Methodology ..... 21
9. Case Study for Universities ..... 22
9.1 Baseline Architecture (Pre-Zero Trust) ..... 22
9.2 Zero Trust-Enhanced Architecture ..... 22
9.3 Comparative Assessment ..... 23
9.4 Generalizability Beyond the Modeled Case ..... 24
10. Results and Discussion ..... 24
10.1 Access Control Granularity ..... 24
10.2 Reduction in Lateral Movement Risk ..... 24
10.3 Regulatory Compliance Alignment ..... 25
10.4 Operational Feasibility ..... 25
10.5 Limitations ..... 25
10.6 Summary of Findings ..... 26
11. Recommendations ..... 27
12. Conclusion ..... 28
References ..... 29
Appendix A: Glossary of Acronyms ..... 30
Appendix B: Mapping of Research Objectives to Sections ..... 31

# List of Figures

Figure 1 Relative prioritization of generative AI threat Categories by likelihood and institutional impact ..... 14

Figure 2 Logical components of a zero trust Architecture deployment, adapted from NIST SP 800-207..... 16

Figure 3 The proposed five-layer Zero Trust framework, mapped to its primary control and corresponding Zero Trust tent..... 18

Figure 4 The four research phases followed in this study , from standards review through to criteria-based evaluation..... 20

Figure 5 Structural comparison of the baseline and Zero Trust-enhanced architectures evaluated in the university case study..... 22

# List Of Tables

Table 1: Structural challenges in higher education IT environments mapped to the framework layer that addresses each one……...11

Table 2: Summary of the proposed five-layer Zero Trust framework for generative AI in higher education……19

Table 3: Comparative assessment of baseline versus Zero Trust-enhanced architecture in the modeled university case study……22

Table 4: Summary of findings against the four evaluation criteria established in the research methodology……...25

Table 5: Glossary of acronyms used throughout this research……..……29

Table 6: Traceability matrix linking each stated research objective to the section(s) in which it is fulfilled……30

# 1. Introduction

Generative artificial intelligence has moved from an experimental novelty to a core operational technology within higher education institutions in a remarkably short period. Universities now deploy large language models for tasks ranging from drafting administrative correspondence and summarizing research literature to powering chatbots that handle student inquiries containing academic records, financial data, and personal identifiers. This rapid adoption has outpaced the development of corresponding security controls, leaving many institutions exposed to a class of risks that traditional IT security frameworks were never designed to address.

Higher education environments present a uniquely challenging security context. Universities are decentralized by nature, with faculties, research centers, and administrative departments often operating semi-independently, each procuring or experimenting with generative AI tools with limited central oversight. Students, faculty, and staff bring a wide range of devices and access patterns, and the academic culture of open collaboration frequently conflicts with the access restrictions that strong security postures require. When generative AI is layered onto this environment, the attack surface expands considerably: prompt injection, data leakage through model outputs, unauthorized fine-tuning on sensitive institutional data, and over-permissioned API integrations all become plausible vectors of compromise.

Zero Trust Architecture (ZTA) offers a conceptual and practical response to this problem. Rather than assuming that any user, device, or application is trustworthy by virtue of being inside the institutional network, Zero Trust treats every access request as potentially hostile until proven otherwise through continuous verification. Applied to generative AI, Zero Trust principles can constrain what data a model is permitted to access, log and monitor every inference request, and ensure that even a compromised AI integration cannot move laterally to other sensitive systems.

This research investigates how Zero Trust Architecture, as formalized in NIST SP 800-207, can be adapted into a practical framework for securing generative AI applications specifically within higher education institutions. The remainder of this paper is organized as follows: Section 2 reviews the background of generative AI adoption in academia; Section 3 surveys the cybersecurity challenges unique to higher education; Section 4 catalogs the specific security threats introduced by generative AI systems; Section 5 introduces the principles of Zero Trust

Architecture; Section 6 reviews related work; Section 7 presents the proposed framework; Section 8 describes the research methodology; Section 9 applies the framework to a university case study; Section 10 discusses the results; Section 11 offers practical recommendations; and Section 12 concludes the paper.

## 1.1 Problem Statement

Higher education institutions are adopting generative AI applications faster than they are adapting their security architectures to govern them. Sensitive student records, research data, and institutional intellectual property are increasingly processed by third-party or self-hosted language models without consistent identity verification, data classification, or monitoring controls. This creates a governance gap between the pace of AI adoption and the maturity of the underlying security posture.

## 1.2 Research Objectives

- Identify the specific categories of security and privacy risk introduced by generative AI applications in academic environments.
- Map Zero Trust Architecture principles onto the operational realities of university IT infrastructure.
- Propose a practical, layered framework for securing generative AI deployments using Zero Trust controls.
- Evaluate the proposed framework against a representative university case study.
- Provide actionable recommendations for institutional IT governance teams.

## 1.3 Scope and Significance

The scope of this research is intentionally bounded to the intersection of three domains: Zero Trust security architecture, generative AI application risk, and the operational constraints specific to higher education institutions. The research does not attempt to evaluate the security posture of any single commercial AI vendor, nor does it propose new cryptographic protocols or detection algorithms; rather, its contribution is an integrative framework that translates existing, well-

established standards into a form directly actionable by university IT governance teams who must secure generative AI deployments with limited specialized staffing.

The significance of this work lies in addressing a gap that is becoming increasingly urgent: as generative AI assistants move from optional productivity tools to embedded components of academic advising, research support, and administrative workflow, the cost of an inadequate security architecture compounds. A framework that institutions can adopt incrementally, prioritizing the highest-impact controls first, offers a practical path forward that does not require a complete security infrastructure overhaul before the first protective measure can be deployed.

# 2. Background of Generative AI

Generative AI refers to a class of machine learning systems, most prominently large language models (LLMs) and diffusion-based image generators, capable of producing novel text, code, images, or other content in response to a prompt. Modern LLMs are trained on vast corpora of text using transformer architectures, enabling them to perform tasks such as summarization, translation, question answering, and code generation with a degree of fluency that has made them attractive for integration into everyday workflows.

In the higher education sector, generative AI adoption has occurred along three broad fronts. First, instructional use, where faculty and students use AI tools for drafting, tutoring, and exploring concepts, raising academic integrity questions alongside security ones. Second, research support, where AI assists with literature review, data analysis, and even hypothesis generation, often requiring access to unpublished or proprietary datasets. Third, administrative automation, where institutions deploy AI-powered chatbots and decision-support tools that directly interface with student information systems, admissions data, and financial records.

Universities increasingly use generative AI in two architecturally distinct ways: by consuming third-party AI services through APIs (where data leaves institutional infrastructure and is processed by an external provider), and by self-hosting open-weight models within institutional infrastructure (where the institution retains full data custody but assumes responsibility for securing the model and its surrounding pipeline). Each approach carries a different risk profile. API-based consumption introduces third-party data handling risk and dependency on external vendor security practices, while self-hosted deployment shifts the security burden entirely onto the institution's own infrastructure, personnel, and monitoring capability.

A further architectural pattern relevant to this research is Retrieval-Augmented Generation (RAG), in which an LLM is connected to an institutional knowledge base, document repository, or database to ground its responses in current, organization-specific information. RAG pipelines are particularly consequential from a security standpoint because they create a direct, often poorly audited channel between a generative model and sensitive internal data stores, making access control at the retrieval layer a critical design consideration.

# 3. Cybersecurity Challenges in Higher Education

Higher education institutions face a security environment that differs structurally from that of typical corporate enterprises, and these differences compound the risks introduced by generative AI adoption.

## 3.1 Decentralized IT Governance

Universities are commonly organized as federations of semi-autonomous faculties, research centers, and administrative units, each with some degree of authority over its own technology procurement. This decentralization, while academically valuable, makes it difficult for a central IT security office to maintain visibility over which generative AI tools are in use, what data they process, and under what contractual or technical safeguards.

## 3.2 High-Value, High-Volume Data

Universities hold large volumes of data attractive to attackers: student personal and financial records, health information from campus clinics, unpublished research with commercial or national security value, and identity documents tied to admissions and HR processes. This makes higher education a persistent target for data breaches independent of any AI-specific risk, and generative AI systems that touch this data inherit and often amplify that exposure.

## 3.3 Open and Heterogeneous User Base

Faculty, staff, students, alumni, visiting researchers, and external collaborators all require some level of system access, frequently from personal and unmanaged devices. This heterogeneity undermines device-trust assumptions that many traditional security models rely on, and complicates the enforcement of consistent authentication and authorization policies.

## 3.4 Resource and Expertise Constraints

Compared to large private-sector enterprises, many universities operate with constrained cybersecurity budgets and limited specialized security staff relative to the scale of their IT estate. This resource gap can delay the adoption of advanced controls such as continuous monitoring, behavioral analytics, and dedicated AI governance functions, even when the underlying risks are well understood.

## 3.5 Legacy Systems and Shadow IT

Long-lived legacy administrative systems, combined with a culture of departmental experimentation, frequently produce shadow IT: tools and integrations adopted without formal security review. Generative AI is particularly susceptible to this pattern, as individual faculty or staff can adopt consumer-grade AI tools and connect them to institutional data with minimal technical barriers.

## 3.6 Summary of Structural Challenges

Table 1 below consolidates the five structural challenges discussed in this section and identifies which layer of the framework proposed in Section 7 is best positioned to mitigate each one. This mapping is revisited in Section 7 once the framework itself has been introduced.

| Structural Challenge | Primary Risk Introduced | Mitigating Framework Layer |
|---|---|---|
| **Decentralized IT governance** | Inconsistent visibility into AI tool usage | Layer 1 — Identity |
| **High-value, high-volume data** | Attractive, concentrated breach target | Layer 2 — Data |
| **Open, heterogeneous user base** | Weak device-trust assumptions | Layer 1 — Identity |
| **Resource and expertise constraints** | Delayed adoption of advanced controls | Layers 1–2 (priority) |
| **Legacy systems and shadow IT** | Unsanctioned, unaudited AI integrations | Layer 3 — Integration |

*Table 1: Structural challenges in higher education IT environments mapped to the framework layer that addresses each one.*

# 4. Generative AI Security Threats

Generative AI introduces a distinct threat taxonomy that extends beyond conventional application security concerns. The following categories, informed by the OWASP Top 10 for Large Language Model Applications, are most relevant to higher education deployments.

## 4.1 Prompt Injection

Prompt injection occurs when an attacker crafts input designed to override a model's intended instructions, potentially causing it to disclose restricted information, execute unintended actions through connected tools, or bypass content and access policies. In a university context, this could allow a malicious actor to manipulate an AI advising assistant into revealing another student's records or internal administrative procedures.

## 4.2 Sensitive Data Exposure and Leakage

Generative AI systems risk exposing sensitive data in two directions: through training or fine-tuning on confidential institutional data that later surfaces in model outputs, and through retrieval-augmented pipelines that pull from sensitive data stores without adequate filtering before content reaches the model's context window.

## 4.3 Insecure Output Handling

When AI-generated output is passed downstream to other systems, such as automated email responses, code execution environments, or document generation pipelines, without validation, it can introduce injection vulnerabilities analogous to classic web application flaws, including cross-site scripting or command injection.

## 4.4 Excessive Agency and Over-Permissioned Integrations

Many institutions connect generative AI assistants to plugins, APIs, or agentic tool chains (such as calendar systems, student information systems, or file repositories) with broader permissions than the AI task actually requires. An over-permissioned integration significantly increases the blast radius of any single compromise.

## 4.5 Model and Supply Chain Risks

Institutions that download open-weight models, fine-tuning datasets, or third-party plugins from public repositories face supply chain risk, including the possibility of poisoned training data, embedded backdoors, or malicious code bundled with model artifacts.

## 4.6 Denial of Service and Resource Exhaustion

Because LLM inference is computationally expensive, generative AI services are susceptible to resource exhaustion attacks where an adversary submits a high volume of complex queries to degrade service availability or inflate operational costs.

## 4.7 Shadow AI and Unsanctioned Tool Use

Faculty, staff, and students adopting consumer AI tools outside of any institutional governance process can inadvertently transmit sensitive data, such as unpublished research, exam content, or student records, to external providers with unknown data retention and training practices.

## 4.8 Prioritizing the Threat Landscape

Not all of the threats catalogued above warrant the same urgency of response. Plotting each threat category against its likelihood of occurrence in a typical university environment and its potential institutional impact helps clarify where mitigation effort should be concentrated first. Figure 1 below summarizes this prioritization, which directly informs the layer ordering of the framework proposed in Section 7.

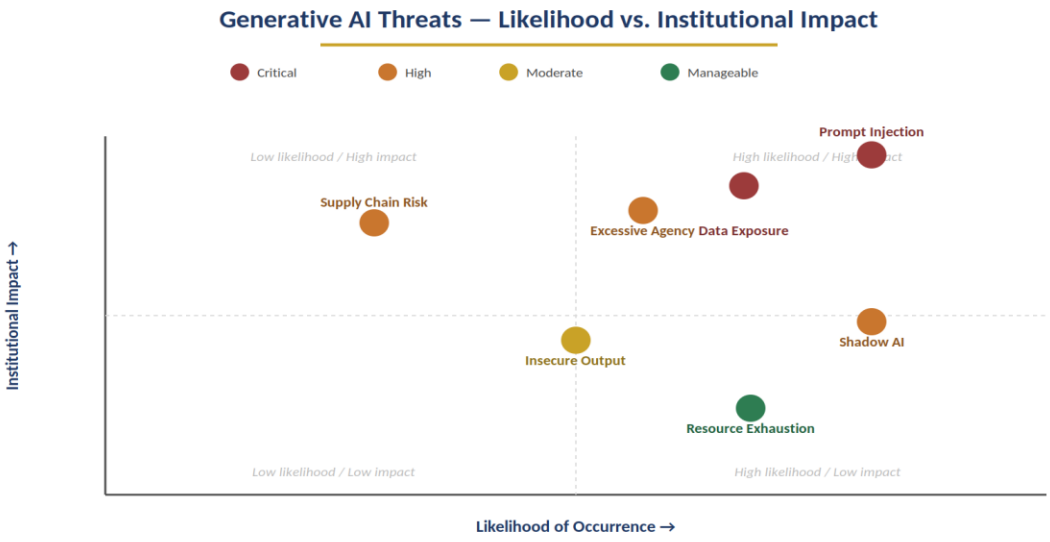
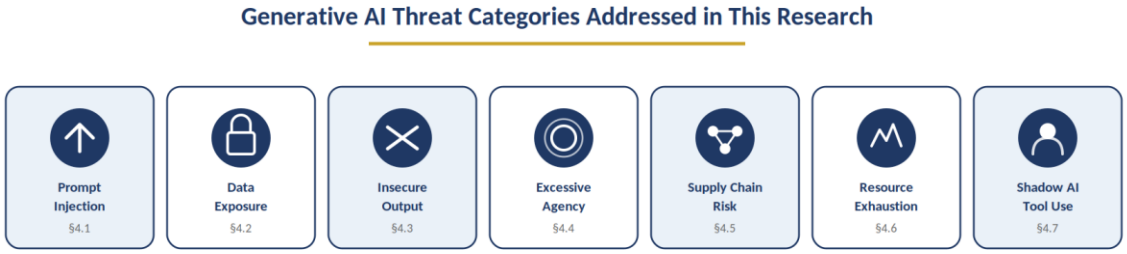



*Figure 1: Relative prioritization of generative AI threat categories by likelihood and institutional impact.*

Sensitive data exposure and prompt injection occupy the critical quadrant, combining both high likelihood and high institutional impact, and are therefore treated as first-priority concerns addressed directly by Layers 2 and 4 of the proposed framework. Excessive agency and supply chain risk, while somewhat less frequent, carry sufficiently high impact to warrant dedicated controls in Layer 3. Shadow AI, though high in likelihood, is comparatively lower in direct technical impact and is addressed primarily through governance and awareness measures in the recommendations of Section 11, rather than through a dedicated technical control layer.




*Each category is mapped to a specific framework layer in Section 7, with priority guided by the likelihood–impact analysis in Section 4.8.*

# 5. Zero Trust Architecture

Zero Trust Architecture is a security model formalized by the U.S. National Institute of Standards and Technology in SP 800-207. Its foundational principle is that trust must never be implicit based on network location; instead, every access request, regardless of where it originates, must be authenticated, authorized, and continuously validated before and during access to a resource.

## 5.1 Core Tenets

- Verify explicitly: every access request is authenticated and authorized using all available data points, including user identity, device posture, location, and behavioral context.
- Use least-privilege access: users, services, and AI agents are granted the minimum level of access required to perform a specific task, for the minimum necessary duration.
- Assume breach: the architecture is designed under the assumption that a compromise has already occurred or will occur, minimizing blast radius through segmentation and continuous monitoring.
- Micro-segment resources: network and data resources are divided into small, independently protected zones rather than relying on a single perimeter boundary.
- Continuously monitor and log: all access and usage activity is logged and analyzed in real time to detect anomalous behavior.

## 5.2 Core Logical Components

NIST SP 800-207 describes a Zero Trust deployment in terms of a Policy Engine, which decides whether to grant access based on policy and contextual signals; a Policy Administrator, which establishes or severs the communication path between a subject and a resource; and a Policy Enforcement Point, which is the gateway through which all traffic to the resource must pass. Surrounding these core components are supporting systems including continuous diagnostics and mitigation (CDM), identity and access management (IAM), security information and event management (SIEM), and threat intelligence feeds, all of which supply the contextual data the Policy Engine uses to make access decisions.

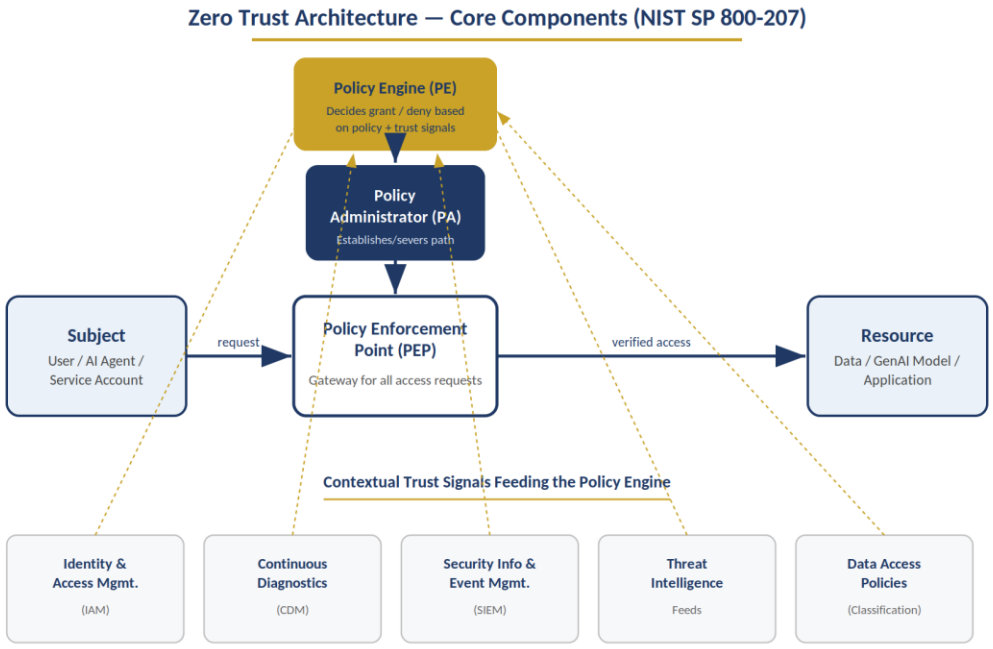



*Figure 2: Logical components of a Zero Trust Architecture deployment, adapted from NIST SP 800-207.*

## 5.3 Why Zero Trust Fits Generative AI

Generative AI systems function as a new category of subject and resource simultaneously: they act as agents making requests to retrieve data (a subject), while also serving as a resource that users and other systems query. Zero Trust's resource-centric, identity-driven model maps naturally onto this duality. By treating each model invocation, each plugin call, and each data retrieval performed by an AI system as a distinct, independently verifiable transaction, institutions can constrain what a generative AI system is able to see and do at a much finer granularity than a traditional network perimeter would allow.

# 6. Related Work and Literature Review

Zero Trust Architecture has been studied extensively as a general-purpose enterprise security model since the formalization of NIST SP 800-207, with widely cited implementation guidance from vendors including Microsoft and Google Cloud, both of which have published Zero Trust reference architectures aimed at cloud and hybrid environments. These works establish the foundational identity-centric, least-privilege design pattern that this research adapts to the generative AI domain.

Separately, the security research community has produced a growing body of work cataloging risks specific to large language model applications. The OWASP Top 10 for Large Language Model Applications provides a structured taxonomy of risks such as prompt injection, insecure output handling, and excessive agency, which this research draws upon in Section 4. The NIST AI Risk Management Framework (AI RMF) further contributes a governance-oriented lens, framing AI risk management around the functions of Govern, Map, Measure, and Manage, and emphasizing that AI-specific risk cannot be addressed by security controls alone but requires organizational governance structures.

Within the higher education context specifically, prior literature on cybersecurity has tended to focus on conventional threats, such as ransomware affecting student information systems, phishing campaigns targeting faculty and staff credentials, and data breaches involving research databases, rather than on generative AI as a distinct risk category. This leaves a gap that the present research aims to address: a synthesis of Zero Trust principles, LLM-specific threat models, and the operational constraints of university IT environments into a single, actionable framework.

Where this research differs from general-purpose Zero Trust guidance is in its explicit treatment of generative AI components, models, retrieval pipelines, plugin integrations, and inference endpoints, as first-class resources and subjects within the Zero Trust policy model, rather than treating AI services as an undifferentiated extension of existing application infrastructure.

# 7. Proposed Framework

This research proposes a five-layer Zero Trust framework for securing generative AI applications in higher education institutions. Each layer corresponds to a distinct control surface within the AI application lifecycle, from identity verification through to continuous monitoring.

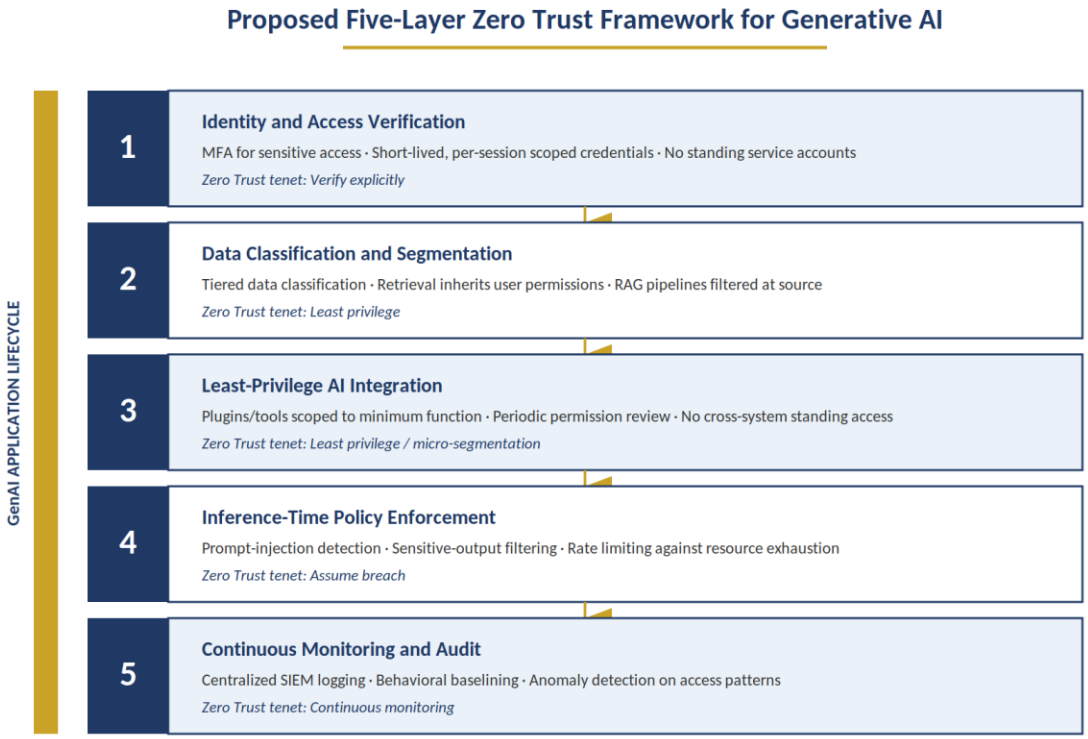



*Figure 3: The proposed five-layer Zero Trust framework, mapped to its primary control and corresponding Zero Trust tenet.*

## 7.1 Layer 1: Identity and Access Verification

Every human user, service account, and AI agent must be assigned a unique, strongly authenticated identity, integrated with the institution's central identity provider. Multi-factor authentication is enforced for any account capable of invoking a generative AI service that touches sensitive data, and AI service accounts are issued short-lived, scoped credentials rather than static API keys.

## 7.2 Layer 2: Data Classification and Segmentation

Institutional data is classified into tiers (for example, public, internal, confidential, and restricted) before any generative AI system is permitted to access it. Retrieval-augmented generation

pipelines are configured so that the retrieval layer enforces the same access control policy as the underlying data source, ensuring an AI system cannot retrieve data the requesting user would not otherwise be authorized to see.

## 7.3 Layer 3: Least-Privilege AI Integration

Plugins, tool calls, and agentic capabilities connected to a generative AI system are scoped to the minimum function required. For example, an AI assistant supporting course registration should be granted read access to course catalog data but no write access to grading or financial systems, even if such systems exist on the same network segment.

## 7.4 Layer 4: Inference-Time Policy Enforcement

A policy enforcement point is placed between users and the generative AI model itself, inspecting both incoming prompts and outgoing completions. This layer performs prompt-injection detection, output filtering for sensitive data patterns (such as student ID formats or financial account numbers), and rate limiting to mitigate resource exhaustion attacks.

## 7.5 Layer 5: Continuous Monitoring and Audit

All inference requests, retrieval operations, and policy decisions are logged to a centralized SIEM platform. Behavioral baselines are established for typical AI usage patterns, allowing anomaly detection to flag unusual volumes of sensitive data retrieval, atypical query patterns, or access attempts outside normal operating hours.

## 7.6 Framework Summary

| Layer | Primary Control | Zero Trust Tenet Applied |
|---|---|---|
| **1. Identity** | MFA, scoped short-lived credentials | Verify explicitly |
| **2. Data** | Classification-aware retrieval filtering | Least privilege |
| **3. Integration** | Scoped plugin/tool permissions | Least privilege / micro-segmentation |
| **4. Inference** | Prompt/output inspection, rate limiting | Assume breach |
| **5. Monitoring** | Centralized logging, anomaly detection | Continuous monitoring |

*Table 2: Summary of the proposed five-layer Zero Trust framework for generative AI in higher education.*

# 8. Research Methodology

This research adopts a qualitative, design-oriented methodology combining literature synthesis with a single-institution case study evaluation. The approach is structured in four phases.

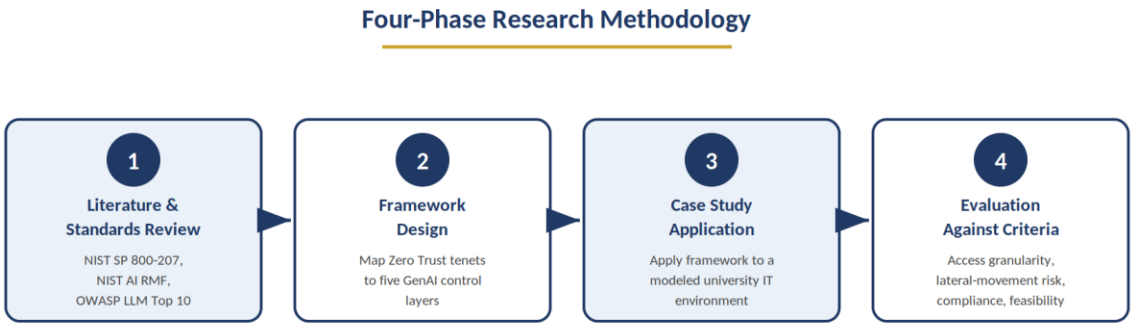



*Figure 4: The four research phases followed in this study, from standards review through to criteria-based evaluation.*

1. Literature and standards review: relevant standards (NIST SP 800-207, NIST AI RMF), industry guidance (Microsoft, Google Cloud Zero Trust documentation), and threat taxonomies (OWASP LLM Top 10) were reviewed to establish the conceptual foundation of the framework.
2. Framework design: the five-layer framework presented in Section 7 was constructed by mapping each Zero Trust tenet onto a corresponding control point within a typical generative AI application architecture, from identity verification through to continuous monitoring.
3. Case study application: the framework was applied to a representative university IT environment, modeled on common architectural patterns observed in higher education (centralized identity provider, departmental data silos, and a mix of third-party and self-hosted AI services), to assess practical feasibility.
4. Evaluation against criteria: the resulting architecture was evaluated against four criteria: access control granularity, reduction in lateral movement risk, regulatory compliance alignment, and operational feasibility given typical university IT resourcing.

This methodology is appropriate for early-stage security architecture research, where the goal is to establish a coherent, implementable design and evaluate its feasibility, rather than to produce statistically generalizable quantitative results from a live production deployment. The case study in Section 9 should accordingly be read as an illustrative feasibility assessment rather than an empirical field trial.

# 9. Case Study for Universities

To evaluate the proposed framework, this research models a representative university environment consisting of a central identity provider, a student information system, a research data repository, and a recently deployed generative AI assistant intended to support student advising and routine administrative queries.

## 9.1 Baseline Architecture (Pre-Zero Trust)

In the baseline scenario, the AI assistant is granted a single service account with broad read access to the student information system in order to answer a wide range of advising questions, and its retrieval pipeline queries the research data repository without independent access checks. Any user authenticated to the campus network can interact with the assistant, and logging is limited to basic request counts without content-level audit.

## 9.2 Zero Trust-Enhanced Architecture

Applying the five-layer framework, the AI assistant's service account is replaced with short-lived, scoped tokens issued per session and tied to the requesting user's own identity and permissions, rather than a single broad service account. The retrieval layer is reconfigured to inherit the access permissions of the authenticated end user, so that a student asking the assistant about their own records cannot, even indirectly, retrieve another student's data. Plugin access to the research repository is removed entirely from the advising assistant's permission set, since it falls outside its functional scope. An inference-time policy enforcement point is introduced to inspect prompts for injection patterns and to redact detected sensitive data formats from outputs. Finally, all requests are logged to a centralized SIEM with behavioral baselining enabled.

## 9.3 Comparative Assessment

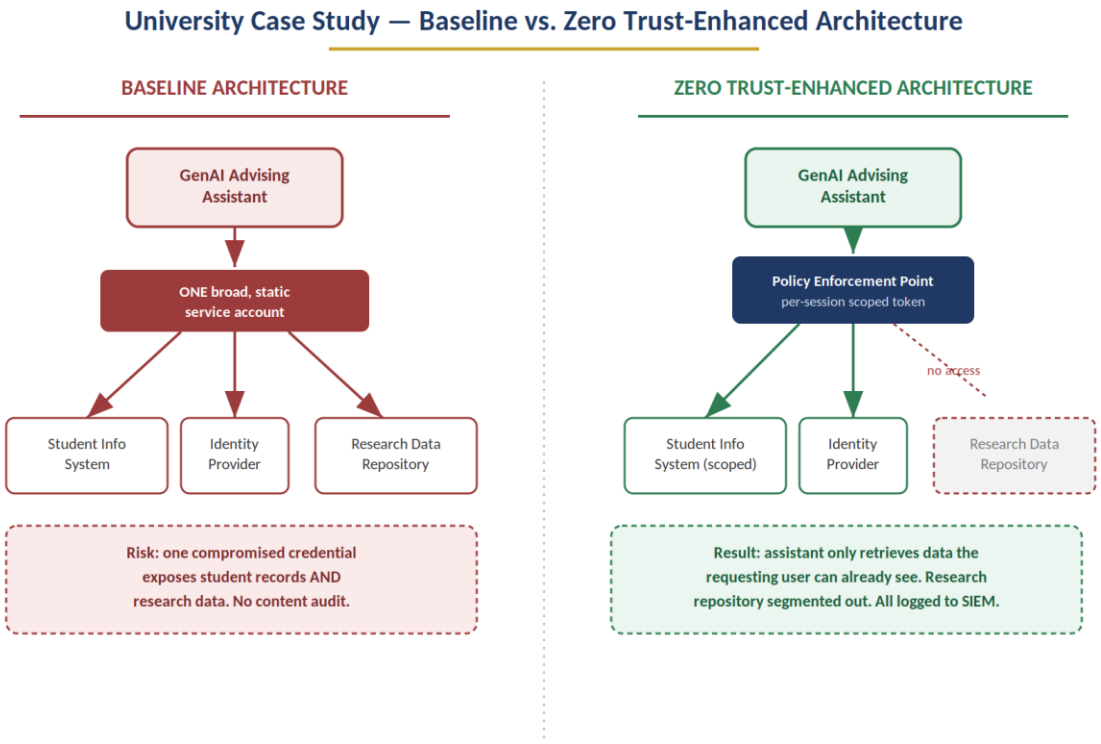



*Figure 5: Structural comparison of the baseline and Zero Trust-enhanced architectures evaluated in the university case study.*

| Dimension | Baseline Architecture | Zero Trust-Enhanced Architecture |
|---|---|---|
| **Access scope** | Broad service account, static credentials | Per-session, user-scoped, short-lived tokens |
| **Data retrieval control** | Unfiltered repository access | Permission-aware, classification-filtered retrieval |
| **Lateral movement risk** | High; single compromised credential exposes multiple systems | Low; segmented, least-privilege scopes |
| **Monitoring depth** | Basic request counts only | Content-aware logging with anomaly detection |

*Table 3: Comparative assessment of baseline versus Zero Trust-enhanced architecture in the modeled university case study.*

This comparison illustrates that the most significant gain from applying Zero Trust principles to the case study environment is not a single technology addition, but the structural shift from a broadly-permissioned shared service account to per-user, per-session scoped access. This shift

alone removes the single largest source of lateral movement risk identified in the baseline architecture.

### 9.4 Generalizability Beyond the Modeled Case

While the case study models a single advising assistant use case, the same structural pattern, replacing standing, broadly-scoped service credentials with per-user, per-session access, generalizes directly to other common university GenAI deployments. A research-support assistant connected to a literature database, an HR chatbot handling employee records, or an admissions-support tool processing applicant data would each benefit from the identical Layer 1 and Layer 2 interventions described here, since the underlying risk (a single over-permissioned credential bridging multiple sensitive systems) is architectural rather than specific to the advising use case. Institutions with multiple concurrent GenAI deployments should therefore treat the identity and data-segmentation layers as shared infrastructure investments rather than per-application configurations, allowing the cost of implementing Layers 1 and 2 to be amortized across every current and future generative AI integration on campus.

## 10. Results and Discussion

The case study evaluation in Section 9 indicates that applying the proposed five-layer Zero Trust framework yields measurable architectural improvements across all four evaluation criteria established in the methodology.

### 10.1 Access Control Granularity

Replacing the single broad AI service account with per-session, user-scoped tokens shifts access control from a coarse, system-level grant to a fine-grained, request-level decision. This directly addresses the excessive agency risk identified in Section 4.4, since the AI assistant can no longer access data outside the scope of the specific user it is currently serving.

### 10.2 Reduction in Lateral Movement Risk

Removing the advising assistant's standing access to the research data repository, and instead requiring any cross-system data need to be explicitly scoped and time-limited, substantially reduces the blast radius of a potential compromise. In the baseline architecture, a single

compromised service credential could expose both student records and research data; in the Zero Trust-enhanced architecture, these remain segmented.

## 10.3 Regulatory Compliance Alignment

The introduction of classification-aware retrieval filtering and content-level audit logging directly supports common data protection compliance requirements, such as demonstrating that access to personal data is limited to authorized purposes and that access events are auditable. This is particularly relevant for institutions subject to data protection regulations governing student and research data.

## 10.4 Operational Feasibility

The framework's layered design allows institutions to adopt it incrementally rather than requiring a single disruptive migration. A university with constrained security staffing, as discussed in Section 3.4, can prioritize Layer 1 (identity) and Layer 2 (data segmentation) first, since these yield the largest risk reduction relative to implementation effort, and add inference-time policy enforcement and advanced monitoring as capacity allows.

## 10.5 Limitations

This research is limited by its reliance on a modeled rather than a live production case study; quantitative metrics such as latency overhead from policy enforcement points and false-positive rates for anomaly detection were not measured empirically and represent an important direction for future, deployment-based research. Additionally, the framework assumes the availability of a reasonably mature central identity provider, which may not hold for all institutions.

## 10.6 Summary of Findings

| Evaluation Criterion | Key Finding |
|---|---|
| **Access granularity** | Per-session, user-scoped tokens replace broad service accounts, eliminating the excessive-agency risk identified in Section 4.4. |
| **Lateral movement risk** | Segmenting the research repository out of the advising assistant's scope removes the single largest blast-radius risk in the baseline design. |
| **Compliance alignment** | Classification-aware retrieval and content-level audit logs directly support common data-protection accountability requirements. |
| **Operational feasibility** | Layered design allows incremental adoption; identity and data-segmentation layers offer the highest risk reduction per unit of implementation effort. |

*Table 4: Summary of findings against the four evaluation criteria established in the research methodology.*

# 11. Recommendations

Based on the framework design and case study evaluation, the following recommendations are proposed for higher education IT governance teams adopting generative AI applications.

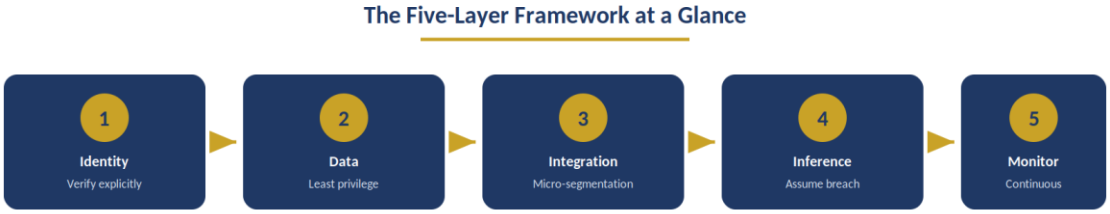
5. Establish a generative AI inventory and approval process so that the institution maintains visibility over which AI tools are in use, what data they access, and under what vendor or hosting arrangement, addressing the shadow AI risk identified in Section 4.7.
6. Eliminate shared, broadly-permissioned service accounts for AI integrations in favor of per-user, short-lived, scoped credentials issued through the central identity provider.
7. Classify institutional data before connecting it to any retrieval-augmented generation pipeline, and enforce that retrieval inherits the requesting user's own access permissions rather than a blanket service-level grant.
8. Scope AI plugin and tool integrations to the minimum functional requirement, and review these scopes on a recurring basis as the AI system's use cases evolve.
9. Deploy an inference-time policy enforcement point capable of basic prompt-injection detection and sensitive-data output filtering, even where dedicated AI security tooling is not yet available.
10. Integrate AI usage logs into the institution's existing SIEM platform rather than treating AI monitoring as a separate, siloed function, enabling correlation with other security events.
11. Adopt an incremental rollout strategy, prioritizing identity and data segmentation controls first, given their high risk-reduction-to-effort ratio relative to more advanced monitoring capabilities.
12. Provide targeted security awareness training for faculty and staff on the risks of unsanctioned AI tool use with institutional data, complementing technical controls with policy and awareness measures.

# 12. Conclusion

Generative AI has become deeply embedded in the operations of higher education institutions, processing sensitive student, research, and administrative data in ways that traditional perimeter-based security models are ill-equipped to govern. This research has presented a five-layer Zero Trust Architecture framework, grounded in NIST SP 800-207 and informed by the OWASP LLM threat taxonomy, designed specifically to address the access control, data protection, and monitoring challenges that generative AI introduces into university IT environments.

The case study evaluation demonstrates that the largest single security improvement available to institutions is the elimination of broadly-permissioned, shared AI service accounts in favor of per-user, scoped, short-lived access, a change that directly reduces lateral movement risk and improves access control granularity without requiring a complete infrastructure overhaul. The framework's layered structure further allows institutions with limited security resources to adopt Zero Trust principles incrementally, prioritizing the controls that offer the greatest risk reduction relative to implementation cost.

Future work should focus on empirical validation of the framework within a live institutional deployment, including quantitative measurement of policy enforcement latency, anomaly detection accuracy, and the operational burden of maintaining fine-grained access scopes at scale. As generative AI capabilities continue to expand into more autonomous, agentic forms within academic environments, the Zero Trust principle of continuous verification will become increasingly central to maintaining institutional trust and regulatory compliance.



# References

[1] National Institute of Standards and Technology (NIST). (2020). Special Publication 800-207: Zero Trust Architecture. U.S. Department of Commerce.

[2] National Institute of Standards and Technology (NIST). (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). U.S. Department of Commerce.

[3] OWASP Foundation. (2024). OWASP Top 10 for Large Language Model Applications.

[4] Microsoft Security. Zero Trust Guidance Center and Zero Trust Deployment Reference Architecture.

[5] Google Cloud. Secure AI Framework (SAIF): A Conceptual Framework for Secure AI Systems.

[6] Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero Trust Architecture. NIST Special Publication 800-207.

[7] Educause. Higher Education Information Security Council (HEISC) resources on cybersecurity governance in academic institutions.

[8] Cloud Security Alliance (CSA). Guidance on Large Language Model (LLM) security and AI governance for enterprise and academic adopters.

[9] Various peer-reviewed research articles on generative AI security, retrieval-augmented generation risk, and higher education cybersecurity, as synthesized throughout this research.

# Appendix A: Glossary of Acronyms

The following table consolidates the technical acronyms used throughout this research for ease of reference.

| Acronym | Full Term |
|---|---|
| **AI** | Artificial Intelligence |
| **AI RMF** | AI Risk Management Framework (NIST) |
| **API** | Application Programming Interface |
| **CDM** | Continuous Diagnostics and Mitigation |
| **GenAI** | Generative Artificial Intelligence |
| **IAM** | Identity and Access Management |
| **LLM** | Large Language Model |
| **MFA** | Multi-Factor Authentication |
| **NIST** | National Institute of Standards and Technology |
| **OWASP** | Open Worldwide Application Security Project |
| **PA** | Policy Administrator |
| **PE** | Policy Engine |
| **PEP** | Policy Enforcement Point |
| **PII** | Personally Identifiable Information |
| **RAG** | Retrieval-Augmented Generation |
| **SIEM** | Security Information and Event Management |
| **ZTA** | Zero Trust Architecture |

*Table 5: Glossary of acronyms used throughout this research.*

# Appendix B: Mapping of Research Objectives to Sections

Table 6 below maps each research objective stated in Section 1.2 to the section of this paper in which it is addressed, supporting traceability between the stated aims and the resulting content.

| Research Objective | Addressed In |
|---|---|
| **Identify security and privacy risks of GenAI in academia** | Section 4 |
| **Map Zero Trust principles onto university IT realities** | Sections 5 and 7 |
| **Propose a layered Zero Trust framework** | Section 7 |
| **Evaluate the framework via case study** | Sections 9 and 10 |
| **Provide actionable institutional recommendations** | Section 11 |

*Table 6: Traceability matrix linking each stated research objective to the section(s) in which it is fulfilled.*